

SOC/L1 - 3.5. Introduction to SOAR

Introduction to SOAR

1 - Introduction

To defend against attacks, a SOC team relies on various security solutions, such as SIEM, EDR, firewalls, and threat intelligence platforms. They also communicate with IT and management teams as part of their processes. However, as threats grow more complex and advanced, SOC teams face challenges like alert fatigue, manual processes, too many disconnected tools, and difficulties in communication across teams.

2 - Traditional SOC and Challenges

Some key capabilities of a SOC include the following:

- **Monitoring and Detection:** This focuses on continuously scanning and flagging suspicious activities within a network environment. It leads to awareness of emerging threats and how to prevent them in their early stages. The monitoring is mainly done through the SIEM. For example, detecting numerous failed login attempts on a critical workstation, or detecting a login from an unknown location, etc
- **Recovery and Remediation:** Organisations rely on their SOC to provide a hub for recovery and remediation when incidents occur. SOC teams operate as first responders when cyber threats are identified. They perform operations such as isolating or shutting down infected endpoints, removing malware, and stopping malicious processes. During this process, they often utilize other security solutions like EDR, firewalls, IAM, etc. For example, isolating an endpoint through EDR, blocking an IP on the firewall, disabling a user on the IAM, etc.

- **Threat Intelligence:** Monitoring environments continuously requires a constant flow of threat intelligence. This ensures that SOC teams have continuous and the latest feeds of threat data, such as IP addresses, hashes, domains, and other indicators. For example, blocking a malicious domain flagged by the threat intelligence feeds.
- **Communication:** The SOC teams not only detect and respond to threats but also coordinate with IT teams and management to effectively communicate the threats and ensure that the incidents are addressed.

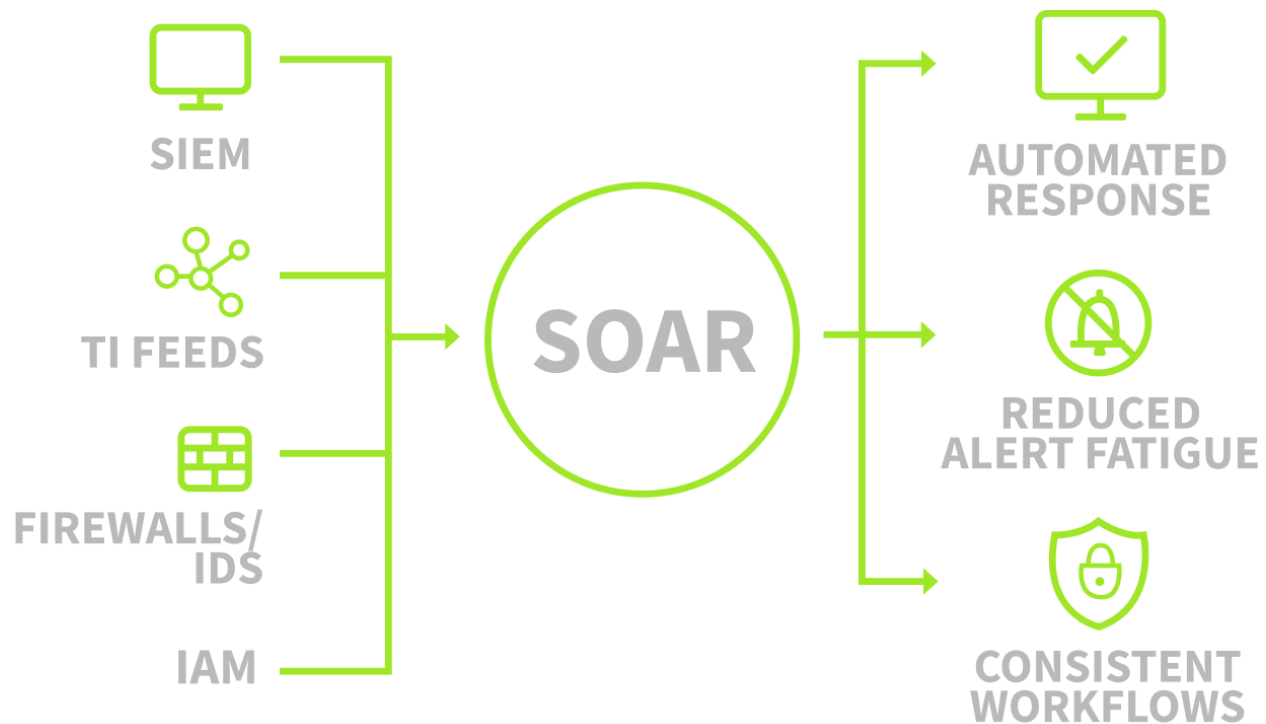
Challenges Faced by SOC

- **Alert Fatigue:** Using numerous security tools triggers a large number of alerts within an SOC. Many of these alerts are false positives or insufficient for an investigation, leaving analysts overwhelmed and unable to address any serious security events.
- **Too many Disconnected Tools:** Security tools are often deployed without integration within an organisation. Security teams are tasked with navigating through firewall logs and rules, which are handled independently from endpoint security logs. This also leads to an overload of tools.
- **Manual Processes:** SOC investigation procedures are often not documented, leading to inefficient means of addressing threats. Most rely on established tribal knowledge built by experienced analysts, and the processes are never documented. This results in slowing down the investigation and increasing response times.
- **Talent Shortage:** SOC teams find recruiting and expanding their talent pool difficult to address the growing security landscape and sophisticated threats. Combining this with the alert overload teams face, security analysts become more overwhelmed with the responsibilities they have to undertake, resulting in less efficient work and extended incident response times that allow adversaries to wreak havoc within an organisation.

How would you describe the experience of an overload of security events being triggered within a SOC? Alert Fatigue

3 - Overcoming SOC Challenges with SOAR

What is SOAR? Security Orchestration, Automation, and Response (SOAR) is a tool that unifies all the security tools used in a SOC. With SOAR, SOC analysts do not need to switch between SIEM, EDR, Firewall, and other security tools for their investigations. They can operate all these tools within a single SOAR interface. Along with unifying the security tools, it also provides ticketing and case management features to the analysts, through which they can document, track, and resolve their incidents in a structured way.



The core strength of a SOAR tool comes from the following three main capabilities:

1. Orchestration: Traditionally, while investigating an alert, a SOC analyst has to switch between multiple security tools for the analysis. For example, during a VPN brute force, the analyst typically switches between the following tools:

1. **SIEM** to check if the user usually uses the subject IP for logging
2. **Threat Intelligence (TI) platforms** to verify the IP's reputation
3. **IAM tool** to disable the user if there was any successful attempt
4. **Ticketing system** to open and track the incident

This manual switching between different tools slows down the process. Orchestration solves this problem by coordinating all these tools together inside the SOAR. It connects different tools from various vendors within the unified SOAR interface. It defines workflows for investigating various types of alerts, known as **Playbooks**. These playbooks are predefined steps that tell the SOAR how to investigate an alert.

For example, the VPN brute force alert we discussed above would have the following playbook:

1. Received alert from SIEM
2. Query SIEM to check if the User normally uses the IP
3. Check TI platforms for the IP's reputation
4. Query SIEM for any successful logins
5. Escalate to containment actions

The above actions are predefined in a playbook for a specific alert. These playbooks are dynamic and usually contain different paths. The result of each step determines the next action. For example, if the user normally uses the IP and the failed attempts were minimal, the playbook may stop early. In the upcoming tasks, we will discuss some real playbooks.

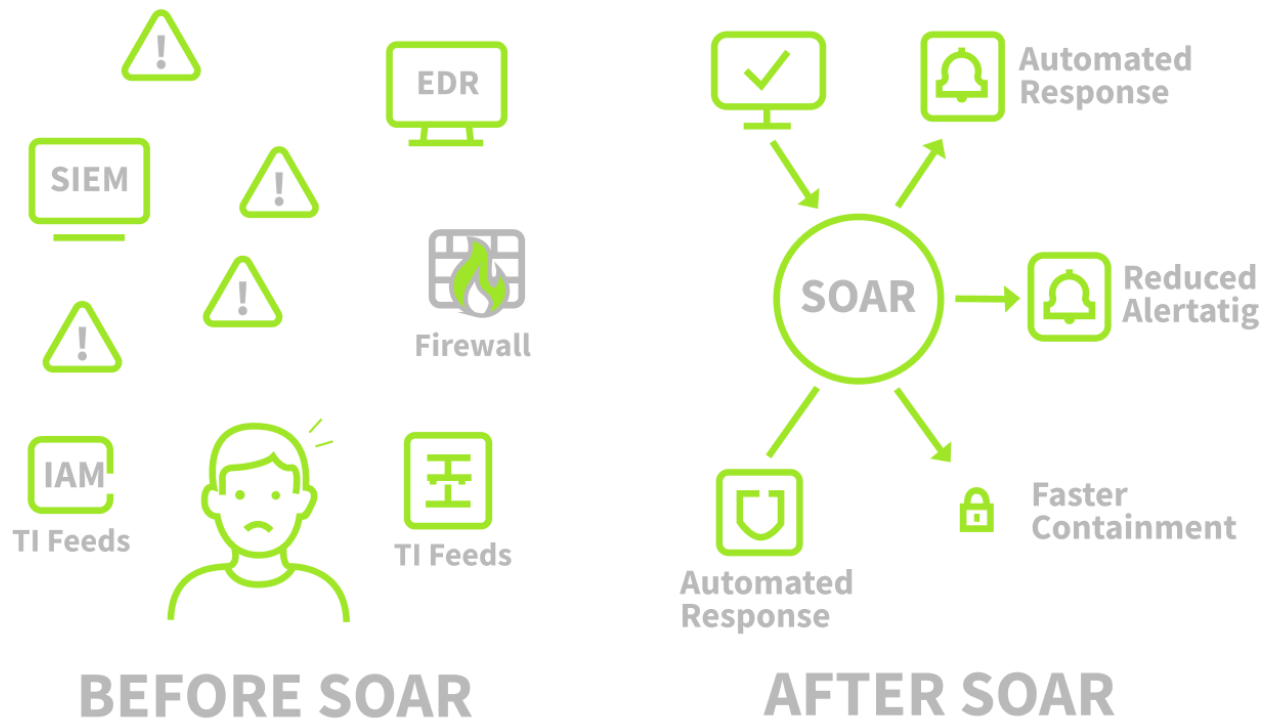
2. Automation: The art of coordinating with multiple tools through predefined actions (Playbooks), which we studied in Orchestration, can be automated. Automation means no more manual clicks needed from SOC analysts. SOAR will itself follow the playbooks. Let's resume the playbook for VPN brute force alert combined with the Automation.

1. SOAR receives the alert from SIEM
2. It automatically queries the SIEM for the user's historical logins
3. It automatically verifies the IP's reputation through TI platforms
4. If the IP is malicious, it automatically disables the user from the IAM
5. Lastly, it automatically opens a ticket in the ticketing system with all the details to initiate an investigation

This saves a tremendous amount of time for SOC analysts. They can handle hundreds of alerts without burning out.

3. Response: SOAR gives the ability to take actions using different tools from one unified interface. It also automates the response, as we saw earlier while looking at its Automation capability. For example, SOAR can follow the playbook of VPN Brute force and block the IP on the firewall, disable the user in the IAM, and open a ticket with all the details.

The Orchestration, Automation, and Response capabilities of SOAR solve the major challenges a SOC team faces. With SOAR, there is no more alert fatigue, most of the processes are automated, and all the different tools are connected for coordination.



The act of connecting and integrating security tools and systems into seamless workflows is known as? Orchestration

What do we call a predefined list of actions to handle an incident? Playbook

4 - Building SOAR Playbooks

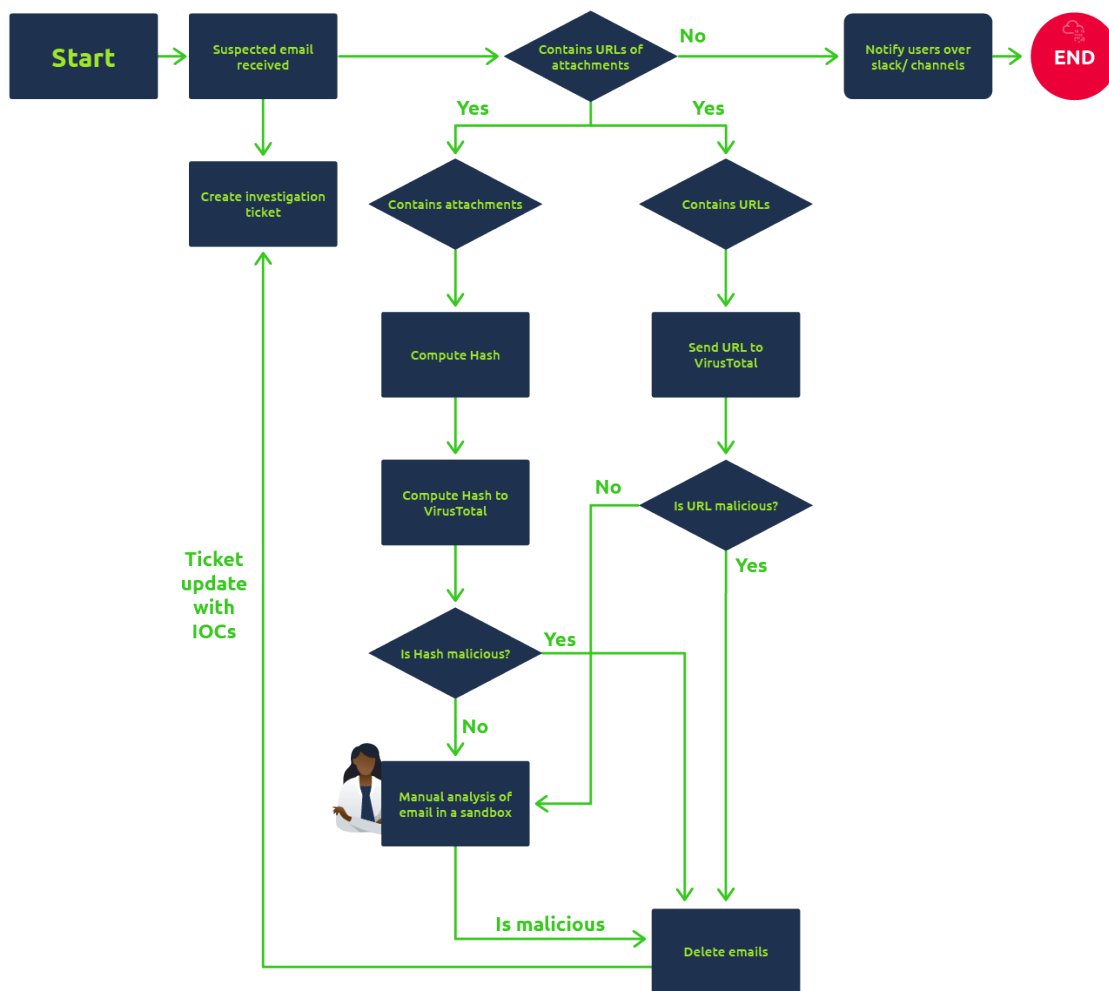
SOC analysts make playbooks for a general category of recurring alerts. Let's have a look at two different playbooks, one for Phishing and one for CVE Patching.

What would this playbook look like?

Imagine you are a SOC analyst experienced in dealing with phishing alerts. You are training a junior analyst on how to respond to a phishing alert. For this, you make a flow diagram for them to take help from while investigating such alerts.

What would you like to add to that flow diagram to assist your junior analyst?

Starting from receiving the alert "Suspicious email received", you will probably tell them the next steps they should take. They should create a ticket and check if the email contains a URL or an attachment. If it does not, just notify the users, but if it does, what would be the next steps? The next steps would further depend on whether it contains a URL or an attachment. So, a lot of "if this happens, do this; else, do this" instructions. This is how a plabook is made. The flow diagram below shows a playbook of phishing, telling what to do at what step.



CVE Patching Playbook

A CVE (Common Vulnerabilities and Exposures) is a vulnerability that is disclosed publicly and assigned a CVE number. As part of vulnerability management, the SOC team has to address newly released CVEs by verifying whether they exist in their network and patching them if they do. An analyst must always be on the lookout for publications on new CVEs and remediation plans. The process can become overwhelming, resulting in a mounting backlog and patches not being applied, leaving the environment more vulnerable. Moreover, this process can take a lot of time and resources of the SOC team since CVEs are released frequently. So, to solve this problem, we can make a playbook for handling the CVEs inside the SOAR tool, just like we did for the phishing case.

This playbook will analyse the CVE details, assess its risk threshold, create a patching ticket, and test the patch before being pushed to the production

```

graph TD
    Start([Start]) --> Step1[Monitor delivery logs]
    Step1 --> Step2[Extract new CVE IDs]
    Step2 --> Step3[CVE ID already published?]
    
    Step3 -- Yes --> End((END))
    Step3 -- No --> Step4[SMB systems patch management tool if CVE requires patches]
    Step4 --> Step5{CVE applicable?}
    
    Step5 -- No --> Step6[SMB systems patch management tool if CVE not applicable]
    Step6 --> End
    
    Step5 -- Yes --> Step7[SMB scans CVE target, assigns analyst]
    Step7 --> Step8[SIC installed system target]
    Step8 --> Step9[SMB identifies current trending patch]
    Step9 --> Step10[SMB queries configurations compatible for patch]
    Step10 --> Step11{Same patch used?}
    
    Step11 -- No --> Step12[Isolate path address]
    Step12 --> Step13[SMB updates SIC modules for patch]
    
    Step11 -- Yes --> Step13
    
    Step13 --> Step14[SMB applies patch to test machines]
    Step14 --> Step15[Logging of test machine results and performance]
    Step15 --> Step16[SMB updates SIC test cluster with results]
    Step16 --> Step17[SIC detects patches for events]
    Step17 --> Step18[SIC analyzes patch values]
    Step18 --> Step19[SMB is no patched paths in vulnerability scan]
    Step19 --> Step20{Security Information}
    
    Step20 -- Yes --> Step21[SIC disables insecure ports]
    Step21 --> Step22[SIC disables misconfigurations]
    Step22 --> Step23[SIC Issues CVE fixes]
    Step23 --> Step24[SMB systems patch management tool if CVE is addressed]
    Step24 --> End
    
    Step20 -- No --> Step25[SMB Systems CVE Fixes]
    Step25 --> End

```

The flowchart illustrates the process flow for CVE remediation. It begins with "Start", leading through "Monitor delivery logs" and "Extract new CVE IDs" to a decision point "CVE ID already published?". If "Yes", it proceeds directly to "END". If "No", it moves to "SMB systems patch management tool if CVE requires patches", then to another decision point "CVE applicable?". If "No", it goes to "SMB systems patch management tool if CVE not applicable" and then to "END". If "Yes", it involves several steps: "SMB scans CVE target, assigns analyst", "SIC installed system target", "SMB identifies current trending patch", "SMB queries configurations compatible for patch", and a decision "Same patch used?". If "No", it leads to "Isolate path address" and then "SMB updates SIC modules for patch". If "Yes", it proceeds to "SMB applies patch to test machines", followed by "Logging of test machine results and performance", "SMB updates SIC test cluster with results", "SIC detects patches for events", "SIC analyzes patch values", and "SMB is no patched paths in vulnerability scan". This leads to a decision "Security Information". If "Yes", it triggers "SIC disables insecure ports", "SIC disables misconfigurations", "SIC Issues CVE fixes", and finally "SMB systems patch management tool if CVE is addressed" before reaching "END". If "No", it proceeds to "SMB Systems CVE Fixes" and then to "END".

From where is the CVE Patching playbook fetching the new CVEs? Advisory lists